

CÓMO IMPLEMENTAR ISO/IEC 27001

Guía práctica para crear, operar, auditar y mejorar un SGSI

Alberto (Al) Leiva

Versión 1.0 - Julio de 2026

Aviso: Esta guía es educativa y no sustituye la norma oficial, asesoría legal ni una auditoría de certificación.

Cómo usar esta guía

- Lea las secciones en orden durante una implementación nueva.
- Utilice las tablas y listas como plantillas iniciales.
- Adapte el SGSI a su contexto y riesgos.
- Consulte la norma oficial para requisitos completos.

Mapa de implementación

Cláusula	Enfoque	Evidencia habitual
4 Contexto	Asuntos, partes interesadas, alcance y procesos	Registro de contexto, partes, alcance y mapa de procesos
5 Liderazgo	Política, funciones y compromiso	Política aprobada, funciones y actas
6 Planificación	Riesgos, tratamiento, objetivos y cambios	Metodología, registro, plan y objetivos
7 Apoyo	Recursos, competencia, concienciación, comunicación y documentos	Capacitación, comunicaciones y control documental
8 Operación	Procesos de riesgo y controles	Registros, tickets, informes y aprobaciones
9 Desempeño	Monitoreo, auditoría interna y revisión	Métricas, auditorías y actas
10 Mejora	No conformidad, acciones y mejora	Acciones correctivas y lecciones

1. Qué es ISO/IEC 27001

ISO/IEC 27001 es la norma de requisitos para establecer, implementar, mantener y mejorar continuamente un sistema de gestión de seguridad de la información (SGSI). Se basa en riesgos y puede adaptarse a organizaciones de distintos tamaños y sectores.

La norma no es una lista de tecnologías. Exige liderazgo, gobierno, gestión de riesgos, objetivos, competencia, control operativo, evaluación del desempeño y mejora continua.

2. Edición vigente y enmienda

Utilice ISO/IEC 27001:2022 junto con ISO/IEC 27001:2022/Amd 1:2024. La enmienda exige determinar si el cambio climático es un asunto relevante para el contexto y reconoce que las partes interesadas pueden tener requisitos relacionados con el clima.

ISO/IEC 27002:2022 proporciona orientación para implementar controles de seguridad de la información. Apoya el diseño de controles, pero no es la norma de requisitos de certificación.

3. Definir el caso de negocio

Aclare por qué se implementará el SGSI: confianza del cliente, contratos, regulación, resiliencia, reducción de riesgos, acceso a mercados o certificación.

Defina resultados medibles como menos riesgos altos, revisiones de acceso más rápidas, mejor preparación ante incidentes y evidencia de auditoría más sólida.

4. Establecer gobierno y funciones

La alta dirección debe aprobar la orientación del SGSI, proporcionar recursos, asignar responsabilidades y revisar el desempeño.

Cree un comité con representantes de seguridad, tecnología, privacidad, legal, recursos humanos, compras, instalaciones, operaciones y unidades de negocio.

5. Comprender el contexto de la organización

Identifique asuntos internos y externos que puedan afectar los objetivos de seguridad. Considere estrategia, cultura, tecnología, proveedores, leyes, condiciones geopolíticas, entorno físico y asuntos climáticos relevantes.

Identifique partes interesadas y requisitos relevantes, incluidos clientes, empleados, reguladores, propietarios, proveedores, aseguradoras y socios.

6. Definir el alcance del SGSI

Documente unidades, ubicaciones, procesos, tecnologías, información, servicios e interfaces incluidos.

Evite un alcance artificialmente reducido que excluya dependencias importantes. Registre límites, exclusiones, servicios compartidos, interfaces con proveedores y justificaciones.

7. Crear el inventario de información, activos y procesos

Inventarie información crítica, sistemas, aplicaciones, servicios de nube, instalaciones, procesos, proveedores y propietarios.

Clasifique según confidencialidad, integridad, disponibilidad, privacidad, requisitos legales y necesidades del negocio.

8. Diseñar la metodología de evaluación de riesgos

Defina criterios coherentes de probabilidad, impacto, nivel de riesgo, aceptación, reevaluación y escalamiento.

Evalúe riesgos para confidencialidad, integridad y disponibilidad e incluya personas, procesos, tecnología, instalaciones, proveedores, nube, privacidad y tecnologías emergentes.

9. Realizar la evaluación de riesgos

Identifique escenarios, activos o procesos afectados, amenazas, vulnerabilidades, controles existentes, probabilidad, impacto y propietarios del riesgo.

Registre el riesgo inherente antes del tratamiento y el riesgo residual después de los controles. Documente supuestos e incertidumbre.

10. Crear el plan de tratamiento

Decida modificar, evitar, compartir o retener cada riesgo. Asigne responsables, recursos, fechas y riesgo residual esperado.

La aceptación debe realizarla un propietario autorizado según criterios definidos. El equipo de seguridad no debe aceptar silenciosamente riesgos empresariales.

11. Seleccionar controles y crear la Declaración de Aplicabilidad

Compare los controles seleccionados con el Anexo A y determine cuáles son aplicables. También pueden provenir de leyes, contratos, tratamiento de riesgos u otros marcos.

La Declaración de Aplicabilidad debe identificar cada control del Anexo A, su aplicabilidad, estado, justificación y referencias de apoyo.

Tema	Controles	Ejemplos
Organizacionales	37	Políticas, funciones, inteligencia, proveedores, nube, incidentes y continuidad
Personas	8	Verificación, condiciones, concienciación, disciplina, trabajo remoto y reporte
Físicos	14	Perímetros, ingreso, áreas seguras, equipos, medios, servicios y eliminación
Tecnológicos	34	Identidad, acceso, malware, vulnerabilidades, registros, redes, cifrado y desarrollo

12. Desarrollar políticas, estándares y procedimientos

Cree una política concisa de seguridad respaldada por estándares temáticos y procedimientos operativos.

Los documentos deben incluir propósito, alcance, funciones, acciones requeridas, excepciones, revisión, aprobaciones y evidencia. No documente controles que la organización no realiza.

13. Implementar controles de personas y proveedores

Considere verificación cuando sea legal, confidencialidad, incorporación, cambios de función, terminación, concienciación, uso aceptable, trabajo remoto, disciplina y reporte.

Para proveedores, realice diligencia debida, establezca cláusulas, controle accesos, supervise el servicio, gestione subcontratistas y prepare una salida segura.

14. Implementar controles técnicos y físicos

Implemente controles según el riesgo: identidad y acceso, configuración segura, vulnerabilidades, cifrado, registros, copias de seguridad, redes, endpoints, desarrollo seguro, nube y detección.

Proteja oficinas, centros de datos, equipos, medios, servicios básicos, condiciones ambientales, áreas seguras y eliminación.

15. Operar el SGSI y conservar evidencia

Opere los controles de forma coherente y conserve aprobaciones, tickets, informes, configuraciones, registros, capacitación, revisiones de acceso, revisiones de proveedores, pruebas y actas.

La evidencia debe demostrar diseño y operación a lo largo del tiempo. Una captura de pantalla aislada suele ser débil sin contexto, fuente, fecha, propietario y población.

16. Monitorear objetivos y métricas

Defina objetivos medibles y alineados con las prioridades del negocio.

Use métricas útiles: tratamientos vencidos, revisiones de acceso, restauraciones exitosas, vulnerabilidades altas, tiempos de respuesta, revisiones de proveedores, excepciones y hallazgos.

17. Realizar auditorías internas

Cree un programa de auditoría basado en riesgos que cubra requisitos y controles durante un ciclo planificado.

Los auditores deben ser competentes y suficientemente independientes. Registre criterios, alcance, métodos, evidencia, hallazgos y seguimiento.

Programa mínimo de auditoría

- Requisitos de las cláusulas 4 a 10
- Controles seleccionados y Declaración de Aplicabilidad
- Procesos de alto riesgo
- Acciones correctivas anteriores
- Cambios significativos

18. Realizar la revisión por la dirección

La alta dirección debe revisar desempeño, cambios de contexto, necesidades de partes interesadas, objetivos, auditorías, incidentes, riesgos, oportunidades, recursos y acciones.

La revisión debe producir decisiones y acciones documentadas, no solo una presentación.

19. Corregir no conformidades y mejorar

Cuando no se cumpla un requisito, contenga el problema, corrijalo, analice causas, determine si existen problemas similares, implemente acciones y verifique su eficacia.

La mejora continua debe alimentarse de auditorías, incidentes, monitoreo, cambios de riesgo, comentarios, desempeño de proveedores y lecciones aprendidas.

20. Preparación para la certificación

La certificación es opcional y la realiza un organismo de certificación acreditado. La Etapa 1 suele revisar preparación y documentación; la Etapa 2 evalúa implementación y eficacia.

Antes de certificarse, complete auditoría interna, revisión por la dirección, acciones correctivas, revisión de evidencia y evaluación de preparación. No afirme estar certificado hasta recibir un certificado válido.

Periodo	Prioridades
Días 1-30	Caso de negocio, gobierno, contexto, alcance, inventario y brechas
Días 31-60	Método de riesgos, evaluación, tratamiento, Declaración de Aplicabilidad y documentos
Días 61-90	Operación, evidencia, métricas, preparación de auditoría y acciones correctivas

Listas y plantillas prácticas

Lista de preparación

- ☐ Patrocinador ejecutivo y responsable del SGSI asignados
- ☐ Contexto y partes interesadas documentados
- ☐ Relevancia climática considerada
- ☐ Alcance del SGSI aprobado
- ☐ Inventario de activos y procesos establecido
- ☐ Metodología de riesgos aprobada
- ☐ Evaluación de riesgos completada
- ☐ Plan de tratamiento aprobado
- ☐ Declaración de Aplicabilidad completada
- ☐ Políticas y procedimientos aprobados
- ☐ Registros de competencia y concienciación disponibles
- ☐ Controles de proveedores operativos
- ☐ Controles técnicos y físicos operativos
- ☐ Objetivos y métricas monitoreados
- ☐ Auditoría interna completada
- ☐ Revisión por la dirección completada
- ☐ No conformidades y acciones tratadas
- ☐ Afirmaciones de certificación revisadas

Campos de registro de riesgos

- ID del riesgo
- Proceso o activo
- Escenario
- Amenaza y vulnerabilidad
- Controles existentes
- Probabilidad
- Impacto
- Riesgo inherente

- Tratamiento
- Propietario
- Fecha
- Riesgo residual
- Aceptación
- Revisión

Campos de la Declaración de Aplicabilidad

- Control del Anexo A
- ¿Aplicable?
- Justificación
- Estado
- Propietario
- Referencia
- Evidencia
- Última revisión

Registro de auditoría interna

- Objetivo y alcance
- Criterios
- Auditor
- Fechas
- Métodos
- Evidencia
- Conformidades
- No conformidades
- Observaciones
- Responsable
- Fecha
- Seguimiento

Errores comunes

- Comprar plantillas y tratarlas como un SGSI terminado.
- Crear demasiados documentos que nadie usa.
- Reducir el alcance para ocultar dependencias críticas.
- Confundir una política con evidencia de operación.
- Aceptar riesgos sin autoridad adecuada.
- Prepararse para la auditoría solo unas semanas antes.
- Afirmar certificación antes de recibir un certificado válido.

Referencias oficiales

[ISO/IEC 27001:2022 official page](#)

[ISO/IEC 27001:2022/Amd 1:2024](#)

[ISO/IEC 27002:2022 official page](#)

[ISO/IEC 27000 family](#)

Licencia

Copyright © 2026 Alberto (Al) Leiva. Licencia CC BY-NC-SA 4.0.